

SQL Injection UNION Attack — Determining the Number of Columns

Vulnerability

SQL Injection — UNION-based SQL Injection

Lab

PortSwigger Web Security Academy

Description

The application was vulnerable to SQL injection through a user-controlled parameter. A **UNION SELECT** payload was used to determine the number of columns returned by the original SQL query.

Steps to Reproduce

1. Open the vulnerable page and identify the parameter that controls the product/category query.
2. Inject the following payload:

```
'+UNION+SELECT+NULL,NULL,NULL--
```

3. The application accepted the injected query successfully.
4. The response confirmed that the original query returned **3 columns**.

Payload

```
'+UNION+SELECT+NULL,NULL,NULL--
```

Impact

An attacker can use a UNION-based SQL injection to manipulate the application's SQL query and potentially retrieve data from other database tables. Determining the column count is an important step before extracting database information through a UNION attack.

Tools

- Browser
- Manual testing
- No Burp Suite used

Remediation

- Use **parameterized queries / prepared statements**.
- Avoid dynamically constructing SQL queries with user input.
- Apply server-side input validation.
- Use database accounts with the minimum required privileges.

OWASP

OWASP Top 10 — A03:2021 Injection

Result

The SQL injection vulnerability was successfully exploited to determine that the underlying query returns **3 columns**.